ملخص اختبار الاختراق
/ريان الرشود

رفع الصلاحيات

- لاخذ جلسة
  - windows
    - hta payload
  - Linux
    - nc
      - ssh
    - Linux
- Web/API
  - PATCH
- Windows
  - winpeas
  - Powerup.ps1
  - Potato family
  - بالهاش
    - Mimikatz
      - اخذ الهاش من الذاكرة
    - Rubeus
      - PTK, PTH
    - Crack hash
      - Hashcat
      - اذا كان يبدأب $ غالبا عشوائي ويستحيل كسره
- Linux
  - Linpeas
  - Groups abuse
  - Sudo
- Metasploit (both)
  - local_exploit_suggester

Web

- Vulnerability scanner
  - Nikto
  - Nuclie
  - Automated Active Scan
    - OWASP ZAP
- Certificate Scanning
  - Check for weak ciphecsuite/protocol
    - Sslscan
    - testssl
- Web Proxy
  - Burpsuite
    - Extensions
      - Active Scan ++
        - تحسين قوة الفحص
      - Retire.js
        - لاكتشاف ثغرات المكتبات بشكل افضل
      - JWT Editor
        - لتعديل الجوت بشكل
      - Turbo intruder
        - Race Condition testing
        - 403 Bypasser
    - Collaborator
      - SSRF
      - Out of bound
        - Blind Command Injection
          - by using base32
  - ZAP
  - Caido
- Web Technology
  - wappalyzer browser extension
  - whatweb
- Files Fuzzing
  - ffuf
    - autofilter
      - -ac
    - follow redirect
      - -r
    - --recursion-depth
      - -recursion
    - add extension
      - -e
    - Filters
      - response size
        - -fs
      - words counts
        - -fw
      - status code
        - -fc
      - regex
        - -fr
- Discovery tools
  - Subdomains
    - subfinder
    - crt.name
    - dnsdumpster
- Injection Tools
  - sqlmap
    - SQLI
      - للحصول على نتيجة ناجحة
        - --batch
          - تعبئة تلقائية للاسئلة
        - --random-agent
          - لتغيير اسم المتصفح
        - -r
          - استعمال ملف
        - --skip-waf
          - تخطي الواف
        - --technique
          - اختيار الاسلوب
          - B Boolean-based blind Blind
          - E Error-based Visible output
          - U UNION query Visible output
          - S Stacked queries Executes multiple queries (;)
          - T Time-based blind Blind
          - Q Inline queries DB-specific inline
        - --tamper
          - تعديل للتخطي
          - between
          - random-case
        - --chuncked
          - شمل
        - -p
          - تحديد المعطى
      - بعد الحصول على النتيجة
        - استعلام اكثر
          - --dbs
            - معرفة قواعد البيانات
          - --tables
            - لعرض جميع الجداول
          - -T
            - لعرض جدول بعينه
          - --columns
            - لعرض جميع صفوف جدول
          - -C
            - لعرض صف
          - --dump-all
            - لجلب كل شيء
        - RCE
          - انشاء ملف على الويبروت
            - --os-shell
          - مسح الكاش
            - --purge
            - --flush-session
        - --level (1-5, default 1)
        - --risk (1-3, default 1)
  - XSS
    - xsstrike
    - xsser
  - SSTI
    - SSTImap
  - XXE (XML Input)
    - XXEinjector
- Brute force
  - Hydra
  - Medusa
  - Burpsuite intruder
- API
  - Scanning
    - wapifuzzer
    - Kiterunner
    - swagger_scanner
  - API qouta Cost
    - Gmapsapiscanner
      - google map
  - Exchange
    - Mailsniper

Mobile

- Virtual Machines
  - Seppuku
  - Mobexler
- Static Analysis
  - Jadx-gui
- Reverse Engineering
  - Frida
    - Ssl pinning bypass script
    - Root prevention bypass
  - Drozer Agent
    - attack surface رؤية سطح الهجوم
- Android studio
  - Rooted emulator
  - Emulator with store
    - لجلب التطبيقات من المتجر
- adb
  - لتفعيل روووت
    - adb root
  - adb shell
    - لبدء جلسة تحكم للجوال
      - استعلام عن التطبيقات
        - package list
        - package list -3
          - استعلام عن تطبيقات الطرف الثالث
      - مسار التطبيقات
        - cd /data/data
  - لعرض الاجهزة الجوال المتصلة بالجلسة
    - adb devices
  - لشبك نظام اخر (كالي)
    - adb connect ip:port+1
      - فتح البورت +1 شرط لسماح الاتصال من ويندوز
        - netsh
  - رفع ملفات الى الجوال
    - adb install pckg.apk
    - adb push filename filedestination
  - adb pull filepath
    - لتنزيل تطبيق من الجوال الى النظام
  - تعديل وكيل الشبكة (البروكسي) الحالي(ويندوز)
    - اضافة
    - ازالة
- Mobsf
  - Automated static alanysis

أدوات مهمة

- لمعرفة المعلومات الخالية عن الشبكة / الجهاز الحالي
  - ipconfig /all
  - ip a
- Ping
  - عدم استلام رد لايعني ان الطرف الاخر طافي قد يكون بروتوكول ICMP ممنوع
  - في حال استلام رد TTL
    - Windows
      - 128
    - Linux
      - 64
- ادوات اساسية
  - لمعرفة القفزات للهدف
    - tracert
      - Traceroute
  - Nslookup
    - لمعرفة ال ip
    - لمعرفة هل هو عام خارجي او داخلي بناء على ال ip
  - لمعرفة الطريق للهدف
    - ممتازة لحل مشكلة شبكة ال VM
      - Ip route
  - Port forwarding
    - ممتازة لربط انظمة VM في شبكة NAT
      - netsh
    - SSH -L
- الهجمات على الشبكة
  - Active Directory
    - ADrecon
    - Powerview
    - Powersploit
    - mimikatz
    - rubeus
    - crackmapexec / nxc
    - certify
  - فحص الشبكة
    - Bloodhound (AD)
      - لجلب ملفاته
        - Bloodhound python
        - Rust hound
        - Sharphound
    - Network hound
  - LAN attacks
    - Ettercap
    - Bettercap
    - arpspoof
  - Wireless
    - Rouge access point
    - Evil twin

الفحص

- فحص البورتات
  - Nmap
    - اساسي
      - Nmap 10.xxx - sCV --reason
    - --reason
      - لاظهار TTL
        - 128
          - Windows
        - 64
          - Linux
      - لاظهار كيف اتخذت القرار
        - ممتاز لاكتشاف سبب اغلاق البورت
    - ممنوع في الشبكة ping اذا كان امر
      - -Pn
    - فحص قائمة
      - Nmap -iL list
  - البروتوكولات
    - Smb
      - Try unauthorized access
        - //10.xx
      - Try Unauthenticated access
        - Smbclient -U '' - N
    - Ftp
      - Try unauthorized access
        - Default credentials
          - ftp:ftp
          - anonymous:anonymous
    - Nfs
      - Similar to smb but for Linux
        - showmount -e
    - RPC
      - Rpcclient
        - rpcclient -U "" IP
      - enum4linux
- تصفح الموقع
  - كشف الملفات
    - Crawl
      - Paracrawler
        - ممتازة لرصد نسخ ارقام التقنيات
      - Katana
    - Force browsing
      - Directory brute force
        - Ffuf -u target.com/FUZZ -w /usr/share/wordlists/dirb/common.txt
          - اذا ظهرت جميع الصفحات في النتيجة اذا يجب تفعيل امر الفلترة التقاطية
            - ffuf -ac
      - vHost Fuzzing
        - Ffuf -u target.com/ -H 'Host: FUZZ.target.com' -w /usr/share/wordlists/dirb/common.txt
    - API ممكن تلقى Burp ناظر كل الطلبات اللي مرت في
    - Google dork
      - site: target.com admin
    - /robots.txt
      - قد تظهر اسماء ملفات مهمة
  - كشف التقنيات
    - Web Technology
      - wappalyzer browser extension
      - whatweb
    - View page source
      - hardcoded credentials ايضا ابحث عن
    - Browser tab title
    - Error pages
      - لا وجود لصفحة معدلة قد يساعد في جمع معلومات كثيرة
    - web extension كشف امتداد الموقع
      - Fuzzing
      - Crawling
        - قد يظهر احد صفحات الامتداد
      - Wappalyzer
    - Nmap -sV
    - HTTP Response
- فحص التطبيق الجوال
  - Static analysis
    - Android
      - Jadx-gui
        - Androidmanifest.xml
          - النظر للصلاحيات
            - هل توجد صلاحيات غير محتاجة ؟
            - انواع الصلاحيات
              - صلاحيات اندرويد
                - android.xxx
              - صلاحيات خاصة بالتطبيق (Custom)
        - strings.xml
        - كلمات حساسة مكتوبة
          - Usernames
          - Passwords
          - API Keys
          - Private IPs
        - شهادة التطبيق
          - debbug certificate?
          - self signed?
          - Expired?
    - IOS
      - info.plist
- فحص الشبكة المحيطة
  - متفاعل
    - Ping sweep
      - Fping
      - Nmap
    - Netdiscover
    - ARP scanning
      - ARP request ارسال (VLAN واحض (فقط في نفس ال ping ادق من
  - خفي
    - استلام برودكاست
      - Arp requests استلام
      - لاستلام هاشات
        - Responder / inveigh
          - Only crack, cannot be used in pass the hash
- فحص خارجي
  - Shodan
- (Mother board) تحديد نوع المزود
  - Mac address (first 3 byte is vendor specific) OUI
    - Mac address lookup
      - https://dnschecker.org/mac-lookup.php
- Mobsf
  - مراجعة التقرير شرط

استعلام عن الثغرات

- بحث عن ثغرة لتقنية / نسخة
  - CVE مراجع
    - AI
      - NIST NVD MCP
    - NIST
    - Cvewatch
    - Snyk
    - Github
  - POC
    - Github
      - 3a7/Cve-watch
        - nomi-sec/PoC-in-GitHub
        - trickest/cve
        - projectdiscovery/nuclei-templates
        - rapid7/metasploit-framework
        - CVEProject/cvelistV5
    - Exploitdb
      - searchsploit
- ادوات فحص ثغرات
  - Nuclie
    - فحص التيمبلت الديفولت لكن كن حذر لو كان الموقع صغير ممكن يطيح
  - Vulnerability Management
    - Tenable
    - Qulas
  - CMS
    - Wpscan
  - Metasploit
  - odoo
    - Odoomap
      - https://github.com/MohamedKarrab/odoomap
- مراجع
  - https://hackviser.com/tactics/pentesting
  - https://ippsec.rocks/?#
  - https://hacktricks.wiki/en/index.html

الأهداف في الهجمات

Web

- Restricted page
  - 403 forbidden
    - 403 jump/403 bypasser extension in burp
    - اضف
      - X-Forward-For: 127.0.0.1
  - 401 unauthorized
    - Try diffrent HTTP METHOD
  - جرب الوصول لملفات وراءها
    - Force browsing
      - ffuf --recursion
- API
  - /api/v1/version
    - غالبا اول هدف للتاكد بوجودها
  - Users
  - Id
    - BOLA/IDOR
      - ان كان رقم
        - قد تكون بهاش ضعيف
- Parameters
  - البحث عنها
    - عشوائي Crawling
    - Parameter fuzzing
      - GET
        - ffuf -u https://target.com/FUZZ
      - POST
        - ffuf -u https://target.com/ -X POST -d 'FUZZ=test'
  - ان وجد
    - language (en)
      - LFI
    - File (page.php)
      - LFI
    - Url (host.com)
      - LFI
      - SSRF
        - Port scan
        - RFI
    - اشياء حساسة ينبغي ان لاترسل
      - Token sent via url
    - Reflected query
      - Number
        - (error رقم كبير جدا (قد يؤدي الى
          - 99999999999999
      - جرب
        - SSTI
        - XSS
      - بيانات تبدو مسترجعة من قواعد البيانات
        - UNION SQLI
    - لها علاقة باسترجاع بيانات من قواعد البيانات
      - SQLI
    - هجمات الحقن الأخرى
- Input field
  - حروف يجب تجربتها
    - هل يخرج رد مختلف او error
      - '
      - ;
      - <
      - HTML injection
  - Reflected
    - XSS
    - SSTI
    - بيانات مسترجعة من قواعد البيانات
      - UNION SQLI
  - Unreflected
    - بيانات ترسل للقواعد البيانات لكن لايعكس شيء
      - Time based SQLI
  - Comment
    - Stored XSS
    - Prompt injection for LLMs (if exist)
  - Execute System command on the server
    - Command Injection
  - other attacks consider testing
    - try SSI payload
    - XSLT
- File upload
  - لمعرفة مسار الملف
    - Browser DevTools
    - Fuzzing
      - /uploads
    - HTTP/API Response
      - ظهور المسار في الرد
  - اذا عرفت مسار الملف
    - webshell ارفع
  - فقط pdf ان كان
    - XSS Via pdf
- Race Condition (on Limited Functions)
  - انواع المحدودية
    - اخذ وقت محدد
    - كمية (مثل المال)
    - عملية ذات استعمال واحد
  - امثلة
    - activation token for 1 use case
      - تفعيل حسابين بتوكن واحدة (وهي استعمال واحد)
    - transfer money
      - ارسال نفس الرسالة قد يضاعف القيمة
    - add money/credit
    - Update email and Login

Mobile

- adb داخل shell على النظام عن طريق
  - Share_preference
    - هب يتم مشاركة بيانات حساسة
  - Logs مراجعة
    - Logcat
      - للتطبيق PID خذ رقم العملية
        - adb shell ps -A | grep com.example.app
      - اقرأ سجلات التطبيق فقط
        - adb shel ps | grep PID
  - Tmp file
    - ابحث هل تم حفظ ملف مؤقت وفيه بيانات
  - database
    - حساسة sqlite3
- Exported في الكود المرجعي يوجد
  - Activists
    - Login bypass
  - Services
    - Intent manipulation
  - Broadcast receivers
    - Privileged actions
  - Content provider
    - Data exposure
- Input field داخل التطبيق
  - SQLI
  - XSS

Database

- Dump tables
- هل يمكن تنفيذ اوامر على النظام
  - shell اذا نعم قم بتفعيل
    - Execute base64 to get a shell (remove spaces =)
  - LFI
- اخذ التشوبه
  - responder

Network

- Active directory
  - Domain controller
    - shell حصول على
      - https://github.com/CobblePot59/ad-cve-privesc
        - PrintNightmare
        - noPac
        - zerologon
    - استخراج التشويهات
      - DCsync
        - secretsdump.py
  - Exchange server
    - هجما ت
      - Proxyshell
    - نقطة نهاية ضعيفة
      - /autodiscover.xml
        - Password spray
    - Guideline
      - https://github.com/kh4sh3i/exchange-penetration-testing
  - اذا كنت خارج النطاق
    - جمع اسماء المستخدمين
      - Ldap anonymous access
      - rpcclinet
      - enum4linux
  - هجمات الشهادات
    - Certighost
- LAN
  - Routers
    - ARP Spoofing on Gateway
      - MITM
    - Join Dynamic Routing protocol as a Router
      - OSPF
      - BGP
  - Switches
    - VLAN
      - Hopping attack (Double tagging with Native VLAN)
      - Switch spoof (DTP protocol)
    - STP
      - Join the STP protocol as switch
  - Servers
    - DNS Spoofing to be gateway
      - MITM
    - DHCP starving
      - استهلاك كل العناوين لتفريغ المساحة للهجوم التالي
        - DHCP Spoofing
  - IoT
    - Default credentials
- Wireless
  - Deauthentication attack
  - فحص بروتوكول التشفير
    - WPA WEP WPA2
  - المستعمل فحص اسلوب المصادقة
    - Personal? Or enterprise
- Login pages
  - Brute force
    - Bypass login
      - ان كانت صفحة خدمة معروفة
        - Default credentials
      - Force browsing
        - للصفحات خلف المسار المقيد
      - SQLi auth bypass
    - rate limit تاكد هل يوجد
    - الاسماء
      - username-anarchy
      - الهدف انشاء قائمة بناء على اشهر الاسماء بناء على جنسية
        - مصادر رسمية باشهر الاسماء
      - user اذا لم يكن عندك اي اسم
        - admin
        - administrator
    - كلمات المرور
      - Seclist
        - Worst 500
      - cupp
      - النمط المتكرر عند البيئة المستهدفة
        - recordfuture
    - OTP bypass
      - 4 digit
        - 10,000 attempt
      - 6 digit
        - 1,000,000 attempt
  - Forget password
    - Users enumeration
      - دليل وجود مستخدم
        - رسالة خطأ تثبت وجود اسم المستخدم
        - وقت الاستجابة للرسالة قد يكون دليل على وجود مستخدم
    - Account takeover
      - استغلال اسئلة استرجاع ضعيفة
        - brute force
      - tokens استغلال
  - CAPTCHA
    - ان كانت ارقام واضحة
      - OCR read by VLM
    - لا تغيير للتوكن في كل عملية
      - Brute force on same request
  - Active directory authentication
    - LDAP injection
    - Pasword spray
  - تأكد ان كانت صفحة المسؤول admin مفتوحة في الانترنت
- Profile
  - File upload
    - معرفة نوع الملف المقبول
      - SVG
        - XXE (also test for any input accept XML)
          - LFI
          - RCE (PHP)
        - XXS
      - GIF
      - JPG
    - تخطي الحماية
      - MIME (Magic bytes)
        - https://en.wikipedia.org/wiki/List_of_file_signatures
      - Content type
        - Fuzzable
      - Double extension
    - Webshell
      - لاختبار الويب شيل الاتسب يجب معرفة الامتداد المستعمل
      - execution اذا عكس محتوى الملف دون تنفيذ
        - جرب امتداد آخر
      - Apache
        - ارفع ملف جديد باسم htaccess
          - AddType application/x-httpd-php .cth
            - php ينفذ cth الان امتداد
  - CSRF
    - تغيير ايميل
    - تغيير كلمة مرور
- Services
  - ثغرات جرجة على خدمات متكررة
    - Tomcat
      - Metasploit module
        - tomcat_jsp_upload_bypass
    - Oracle erp
      - CVE-2022-21587
    - SharePoint
      - CVE-205-53770
- HTTP verbs (Methods)
  - جرب
    - PUT
    - PATCH
    - DELETE
      - خطيرة
  - 405 Unsupported Method
    - جرب مختلف الميثود
      - GET
      - POST
      - HEAD
  - wordlist جربها كلها من
- CORS misconfigurations
  - اذا جاء الشرطين
    - Allow origin *
    - Credentials trrue
- X-Frame-options
  - اذا لم يوجد اي تقييد
    - Clickjacking